

Table of Contents

Cisco Secure Workload — NIST SP 800-207A

Reference Design | PDP/PEP/PA/PIP Implementation Guide

Version: 1.0

Standard: NIST SP 800-207A (Public Draft) — ZTA Model for Access Control in Cloud-Native & Multi-Cloud Environments

Environment: Hybrid (On-Premises + AWS / Azure / GCP)

△ **Draft Notice:** NIST SP 800-207A is in public draft / comment stage. This reference design is anchored to the stable PDP/PEP/PA/PIP logical component model, which is consistent with SP 800-207 and unlikely to change materially. Sections derived from draft-specific content are marked **[DRAFT REF]**. Verify against the final published standard before use in formal audit submissions.

Reader's Guide

Who this is for. Enterprises extending zero-trust principles across satellite locations, multi-cloud environments, and partner boundaries; and security architects who already have an 800-207 baseline and need to operationalize it.

If you haven't read the [800-207 reference design](#) yet, start there. 800-207A assumes you understand the seven tenets and is concerned with *how the components actually wire together*.

Questions this reference design helps you answer:

- *Where in my stack do the Policy Decision Point (PDP), Policy Enforcement Point (PEP), Policy Administrator (PA), and Policy Information Point (PIP) physically live today? Are any of these roles unimplemented or implicit?*
- *Can I trace a single access transaction end-to-end through these four components and produce a timeline of what each one decided?*
- *In a multi-cloud environment, do I have a single PDP that brokers decisions across clouds, or one PDP per cloud? What are the trade-offs for my use cases?*
- *What evidence proves that my PEP is actually enforcing what the PDP decided, rather than silently failing open or stale?*
- *For my use case (satellite office, multi-cloud, cross-enterprise collaboration), which 800-207A reference architecture is closest and where does CSW fit?*

What you'll need. Solid familiarity with NIST SP 800-207, an inventory of your cloud environments and their identity boundaries, your current policy decision and enforcement tooling

map (CSPM, SASE, EDR, identity), and a sense of which use cases (sections 7.1 – 7.3) match your environment.

Where to start. Section 1 if you need the 800-207A vs. 800-207 delta first; sections 2–5 walk PDP, PEP, PA, PIP one at a time; section 6 demonstrates an end-to-end access transaction trace; section 7 maps your use case to a reference architecture; section 9 if you're packaging evidence.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope	Install	Days 1–10

Phase	Goal	Key CSW actions	Typical duration
	workload in CSW	agents/connectors ; apply compliance labels; create scope	
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- CSW Defend as PDP/PEP mapping with traceable components
- Telemetry as PIP for cloud-native ZTA architectures
- Logical-component evidence for draft 800-207A reviews

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview — 800-207A vs. 800-207

	SP 800-207	SP 800-207A
Focus	Seven ZTA tenets + logical architecture	PDP/PEP/PA/PIP component model + access transaction flow
Output	"Does our architecture satisfy ZTA?"	"How do we implement ZTA components operationally?"
Primary audience	CISOs, architects	GRC, security engineers, cloud architects
CSW mapping	Tenet-by-tenet (see companion doc)	Component-by-component (this document)

CSW in the 800-207A model (illustrative mapping):

- **PEP analogue** → CSW software sensor (enforcement at workload level)
- **PDP analogue** → CSW policy engine for network / workload connection decisions
- **PA analogue** → CSW policy workspace (policy authoring, deployment, audit)
- **PIP analogue** → CSW telemetry (vulnerability, process, ADM baseline, flow context)

This mapping is a practical decomposition for workload segmentation discussions, not a claim that CSW implements every possible 800-207A PDP / PEP / PA / PIP responsibility across identity, data, endpoint, and enterprise policy systems.

2. PDP — Policy Decision Point

What 800-207A Requires

The PDP evaluates every access request and issues a decision: allow, deny, or redirect. It must:

- Consume posture signals from the PIP continuously
- Apply policy authored by the PA
- Re-evaluate on every access transaction — not just session establishment
- Log every decision for audit

CSW Implementation

Policy Engine Configuration:

CSW UI → Defend → Segmentation

- Policy Workspace: [Your-ZTA-Workspace]
- Mode: Enforcement (after simulation validation)
- Priority: Absolute Policies first, then ranked allowlist

Absolute Policies (CSW hard denials – never overridden within the workspace):

```
DENY: Any → Sensitive-Scope          # Default deny inbound
DENY: Sensitive-Scope → Internet      # No direct internet egress
DENY: Any → Sensitive-Scope (port 80, 21, 23, 389) # Non-compliant protocols
```

Allowlist Policies (CSW conditional allows):

- ```
ALLOW: [Source Workload] → [Dest Workload] (port X)
→ Derived from ADM output – actual observed traffic
→ Each rule = one approved access transaction pattern
```

#### Vulnerability-Aware PDP (Posture-Informed Decisions):

Workflow: CSW vulnerability alert → compensating policy → PDP behavior change

Step 1: CSW detects Critical CVE on Workload Y

Step 2: Alert fires → SOAR playbook triggered

Step 3: SOAR calls CSW API:

```
POST /openapi/v1/policies
{
 "workspace": "ZTA-Enforcement",
 "name": "vuln-restrict-WorkloadY",
 "priority": "ABSOLUTE",
 "action": "DENY",
 "src": "ANY",
 "dst": "WorkloadY",
```

```
 "comment": "Compensating control – CVE-XXXX-YYYY unpatched"
}
```

Step 4: CSW policy now denies workload-network access to Workload Y except admin jump-host

Step 5: On patch completion → SOAR removes compensating policy

#### **PDP Decision Audit:**

CSW UI → Investigate → Flow Search

→ All flows: ALLOW decisions (connection established)

→ Filter: "Denied" → DENY decisions (policy violation)

→ Export: Full decision log with timestamp, source, dest, rule matched

→ Retention: Configure minimum 12 months for ZTA audit

---

### 3. PEP — Policy Enforcement Point

#### What 800-207A Requires

The PEP must:

- Sit inline between subject and resource — not at perimeter only
- Act on PDP decisions in real time
- Monitor active connections throughout their lifetime
- Be able to terminate connections when policy changes mid-session
- Operate consistently across all environments (on-prem and cloud)

#### CSW Implementation

##### **Sensor Deployment (PEP installation):**

# *Linux – RHEL/CentOS*

```
rpm -ivh tet-sensor-<version>.rpm
```

```
systemctl enable csw-agent && systemctl start csw-agent
```

# *Linux – Ubuntu/Debian*

```
dpkg -i tet-sensor-<version>.deb
```

```
systemctl enable csw-agent && systemctl start csw-agent
```

# *Windows*

```
msiexec /i <Cisco-generated-CSW-agent>.msi /quiet
```

# *Verify PEP is active:*

CSW UI → Manage → Agents

→ Status: Active (green)

→ Policy sync: Current

→ Last heartbeat: < 60 seconds ago

**PEP Enforcement Modes:** | Mode | Behavior | When to Use | |---|---|---| | Monitoring | Observe only — log flows, no enforcement | Initial ADM phase | | Simulation | Test policy decisions — log would-block events | Pre-enforcement validation | | Enforcement | Full PEP — allow/deny per policy | Production ZTA state |

**PEP Progression (mandatory — do not skip simulation):**

Week 1–4: Monitoring mode → ADM collects baseline  
Week 5–6: Simulation mode → Validate no false positives  
CSW UI → Defend → Workspace → View Simulation Results  
→ Review all "would-deny" events  
→ Work with app owners to resolve legitimate flows  
Week 7+: Enforcement mode → Full PEP active

**Connection Termination (mid-session policy change):**

Scenario: SOAR isolates workload during active incident

Step 1: Analyst triggers isolation in SOAR  
Step 2: SOAR calls CSW API → pushes DENY ALL policy for WorkloadZ  
Step 3: CSW PEP on WorkloadZ:  
→ Drops all new inbound connections immediately  
→ Terminates existing connections within policy sync interval  
→ Logs termination event with timestamp and triggering policy

Evidence: Connection termination log → CSW UI → Alerts → Policy Enforcement

**Agentless PEP (cloud workloads without sensor):**

CSW UI → Platform → External Orchestrators  
→ AWS: Cloud connector → VPC Flow Log ingestion  
+ CSW pushes rules to Security Groups via API  
→ Azure: Cloud connector → NSG Flow Log ingestion  
+ CSW pushes rules to NSGs via API  
→ GCP: Cloud connector → VPC Flow Log ingestion

Note: Agentless = visibility + cloud-native enforcement  
Agent-based = full inline workload-level PEP enforcement  
Agent preferred for NIST 800-207A compliance

---

## 4. PA — Policy Administrator

### What 800-207A Requires

The PA must:

- Author policy based on PDP decisions and operator intent
- Deploy policy to PEPs in a controlled, auditable manner

- Maintain complete version history of all policy changes
- Support dynamic policy updates (automated and manual)
- Provide rollback capability

## CSW Implementation

### Policy Workspace as PA:

CSW UI → Defend → Segmentation

- Create Workspace: "800-207A-ZTA-Policy"
- Scope: [Target scope – start broad, narrow with ADM]
- Import ADM: Pull discovered flows as proposed policy baseline
- Review: Approve/reject each proposed rule
- Simulate: Run simulation before enforcement
- Enforce: Promote to enforcement after validation

### PA Change Management Process:

1. PROPOSE: Engineer drafts new policy rule in workspace (Draft state)
2. REVIEW: Security lead reviews – adds comment/approval in workspace
3. SIMULATE: Run simulation – validate no legitimate traffic blocked
4. APPROVE: CISO/security owner approves enforcement
5. ENFORCE: Promote workspace to Enforcement mode
6. AUDIT: Change recorded in workspace version history:
  - Who made the change (operator ID)
  - What changed (rule added/modified/deleted)
  - When (timestamp)
  - Simulation results (pass/fail)

### API-Driven PA (Dynamic Policy Automation):

*# CSW REST API base*

`BASE_URL="https://<csw-cluster>/openapi/v1"`

`API_KEY="<your-api-key>" # Manage → API Keys`

*# Create a new policy rule (PA function via API)*

```
curl -X POST "$BASE_URL/policies" \
-H "X-Tetration-API-Key: $API_KEY" \
-H "Content-Type: application/json" \
-d '{
 "workspace_id": "<workspace-id>",
 "policy_name": "allow-svc-a-to-svc-b",
 "action": "ALLOW",
 "src_filter": {"name": "Service-A-Scope"},
 "dst_filter": {"name": "Service-B-Scope"},
 "l4_params": [{"port": [443, 443], "proto": 6}]
}'
```

*# Delete a policy rule (PA revocation via API)*

```
curl -X DELETE "$BASE_URL/policies/<policy-id>" \
-H "X-Tetration-API-Key: $API_KEY"
```

### PA Rollback:

CSW UI → Defend → Workspace → Version History

- Select prior version
- Compare: Current vs. Prior (diff view)
- Rollback: Restore prior version
- Rollback is itself logged as a versioned change

---

## 5. PIP — Policy Information Point

### What 800-207A Requires

The PIP must provide continuous, real-time attribute signals to the PDP across three domains:

1. **Subject attributes** — who/what is requesting access
2. **Resource/device posture** — health state of the requesting and target entities
3. **Environmental context** — current threat conditions, network state, anomalies

### CSW Implementation

#### Workload Posture PIP (Device/Resource Domain):

CSW Vulnerability Feed:

- Continuous vulnerability exposure visibility – no scheduling required
- Per-workload CVE inventory with CVSS score
- SIEM export: Kafka/Syslog → real-time posture feed
- API query: GET /openapi/v1/vulnerabilities?workload=<id>

Process Integrity PIP:

- CSW monitors all running processes per workload
  - Process hash database: approved vs. unknown
  - Alert: New process not in ADM baseline
  - Alert: Process hash change (binary modified)
- CSW UI → Alerts → Process Anomaly → Enable all triggers

#### Environmental Context PIP (Network Domain):

ADM Baseline as Environmental PIP:

- ADM establishes "normal" environment baseline
- Any deviation = environmental anomaly signal
- New flow not in ADM → alert → PDP can tighten access
- New external IP contacting internal workload → alert

Configure environmental alerts:

- CSW UI → Alerts → Create Alert
- Trigger: New flow not matching ADM baseline

Scope: All sensitive scopes  
Severity: High  
Action: SIEM + email + Webex notification

### **Subject/NPE Identity PIP:**

Non-Person Entity (NPE) identification per access request:

CSW captures per flow:

- Source workload identity (hostname, labels, scope)
- Initiating process name and hash
- Parent process (process tree context)
- User context (if OS-level user tracking enabled)

API query for NPE identity context:

GET /openapi/v1/flowsearch

Filter: dst=<resource-workload>, time=<window>

Returns: src\_workload, process\_name, process\_hash, user

### **Aggregated PIP — SIEM Integration:**

CSW UI → Platform → Data Export

→ Kafka (recommended for real-time):

Topic: csw-flows, csw-alerts, csw-vulnerabilities

Consumer: SIEM Kafka connector

→ Syslog:

Protocol: TCP (reliable delivery)

Format: CEF or JSON

Destination: SIEM syslog receiver

SIEM receives from CSW PIP:

- All flow events (subject + resource identity)
- Vulnerability state changes (posture PIP)
- Process anomaly alerts (integrity PIP)
- Policy violation events (enforcement PIP)
- ADM baseline deviations (environmental PIP)

Cross-correlate in SIEM with:

- Identity PIP: IdP login events (Okta, Azure AD)
- Endpoint PIP: EDR alerts (Cisco XDR, CrowdStrike)
- Threat Intel PIP: Cisco Talos IOC feeds

---

## **6. 800-207A Access Transaction — Step-by-Step Trace**

**[DRAFT REF] — Access transaction model from 800-207A public draft**

Scenario: Service A (client workload) → Service B (API server) on port 443

T=0ms    Service A process initiates TCP SYN to Service B:443

T=1ms CSW PEP (sensor on Service B) intercepts SYN packet  
→ Captures: src\_ip, src\_workload\_id, dst\_port=443, proto=TCP

T=2ms PEP queries local PDP (distributed policy engine on sensor):  
Input attributes:  
src\_scope: "App-Tier"  
dst\_scope: "Data-Tier"  
dst\_port: 443  
protocol: TCP  
src\_vuln: CVSS\_max=4.2 (no critical CVEs)  
src\_process: "java" hash=<approved>  
flow\_in\_ADM: YES (approved flow)

T=3ms PDP evaluates against active policy workspace:  
Rule match: ALLOW App-Tier → Data-Tier (443/TCP) ✓  
Decision: ALLOW  
Decision ID: <uuid> logged to telemetry

T=4ms PEP allows TCP SYN to complete → handshake proceeds  
Session logged: src, dst, process, user, decision\_id, timestamp

T=ongoing CSW monitors session: bytes, duration, behavioral deviation  
→ Any anomaly mid-session → alert → SOAR can trigger isolation

T=end Session terminates (FIN/RST)  
Full session record: start, end, bytes\_in, bytes\_out, process, decision  
→ Exported to SIEM for ZTA audit trail

---

## 7. Use Case Implementation Guides

### Use Case 1 — Enterprise with Satellite Facilities **[DRAFT REF]**

#### Scope Architecture:

|               |                                                 |
|---------------|-------------------------------------------------|
| HQ-Sensitive  | → Default-deny inbound from Branch scopes       |
| HQ-Shared     | → Allowlist: approved Branch-to-HQ flows only   |
| Branch-[Site] | → Default-deny inbound from other Branch scopes |
| Management    | → Jump-host only access to all sensitive scopes |

#### Key policies:

DENY: Branch-\* → HQ-Sensitive (default)  
ALLOW: Branch-A → HQ-Shared (specific approved ports)  
DENY: Branch-A → Branch-B (no lateral branch-to-branch)  
LOG: All cross-facility flows (full audit trail)

## Use Case 2 — Multi-Cloud Enterprise [DRAFT REF]

Cloud connector setup per provider:

AWS: IAM Role → VPC Flow Logs + tag sync  
Azure: Service Principal → NSG Flow Logs + resource group sync  
GCP: Service Account → VPC Flow Logs + label sync

Unified scope across clouds:

Cloud-PHI-Zone (spans AWS + Azure + on-prem PHI workloads)  
Cloud-App-Tier (spans GCP + Azure app workloads)  
Cloud-Data-Tier (spans AWS RDS + on-prem databases)

Policy: Same allowlist workspace governs ALL cloud workloads  
No per-cloud policy fragmentation  
ADM discovers cross-cloud dependencies automatically

## Use Case 3 — Collaboration Across Enterprise Boundaries [DRAFT REF]

Partner access model:

Scope: External-Partners-[PartnerName]

Onboarding workflow:

Step 1: Document approved access in BAA/contract  
Step 2: Create partner-specific scope in CSW  
Step 3: Add partner IP ranges / workload labels to scope  
Step 4: Create allowlist: Partner-Scope → Approved-Resource (port X only)  
Step 5: Enable full flow logging for partner scope  
Step 6: Quarterly review: re-validate partner flows vs. contract scope

Revocation (instant):

CSW API → DELETE partner allowlist rules  
→ Partner access removed within policy sync interval  
→ No network reconfiguration required  
→ Revocation logged in workspace version history

---

## 8. Gap Closure — Complementary Cisco Portfolio

| 800-207A Requirement    | CSW Gap                   | Cisco Complement                    |
|-------------------------|---------------------------|-------------------------------------|
| User identity PIP       | Process/NPE identity only | Cisco Secure Access + Okta/Azure AD |
| MFA / step-up auth      | Not in CSW scope          | Duo Security                        |
| North-south user PEP    | East-west primary         | Cisco Secure Access (ZTNA/SWG)      |
| Device certificate auth | Network path only         | Cisco ISE + Secure Client           |

| 800-207A Requirement         | CSW Gap                            | Cisco Complement                   |
|------------------------------|------------------------------------|------------------------------------|
| External threat intel PIP    | Internal telemetry only            | Cisco XDR + Cisco Talos            |
| Agentless inline enforcement | Visibility only (cloud connectors) | Cloud-native SG/NSG + CSW API push |

## 9. Evidence Checklist for 800-207A Assessment

| Component | Evidence                           | CSW Location                | Cadence           |
|-----------|------------------------------------|-----------------------------|-------------------|
| PDP       | Decision log (allow/deny per flow) | Flow Search export          | Continuous        |
| PDP       | ADM-to-policy traceability         | ADM + Workspace comparison  | Quarterly         |
| PEP       | Sensor deployment inventory        | Manage → Agents → Export    | Monthly           |
| PEP       | Enforcement log (blocks)           | Alerts → Policy Violations  | Real-time         |
| PEP       | Connection termination log         | Alerts → Enforcement Events | On-demand         |
| PA        | Policy workspace version history   | Defend → Workspace History  | Per change        |
| PA        | Simulation validation log          | Defend → Simulation Results | Per policy change |
| PA        | API-driven change log              | Platform → Audit Log        | Per API call      |
| PIP       | Vulnerability posture report       | Investigate → Vulnerability | Weekly            |
| PIP       | Process baseline + anomaly log     | Alerts → Process Anomaly    | Real-time         |
| PIP       | ADM environmental context          | Investigate → ADM           | Quarterly         |
| All       | SIEM integration config            | Platform → Data Export      | Continuous        |

## Related Frameworks

- [NIST SP 800-207 — ZTA Seven Tenets](#) — the architectural prerequisite for 800-207A.
  - [CISA Zero Trust Maturity Model v2.0](#) — the maturity-tier view that maps onto the same logical components.
  - [NIST SP 800-53 Rev 5](#) — AC, SI, SC families that the PDP/PEP/PA/PIP architecture operationalises.
- 

*Customer-facing guidance. Tailor examples and scope notes to your environment before formal audit submission.*

*For full NIST 800-207A ZTA coverage, pair CSW with complementary identity, access, and detection controls (for example: Cisco Secure Access, Cisco ISE, Cisco XDR, and Cisco Talos). [DRAFT REF] sections based on NIST SP 800-207A public draft — verify against final publication.*